

Detecção de Websites de Phishing com Aprendizado de Máquina

Alexandre Eiji Tomimura Carvalho¹, João Pedro Pioltini de Oliveira¹,
Matheus Veiga Bacetic Joaquim¹

¹Faculdade de Computação e Informática – Universidade Presbiteriana Mackenzie
Ciência da Computação – Inteligência Artificial – 7º N
São Paulo – SP – Brasil

RA: 10371680 (Alexandre), 10425643 (João Pedro), 10425638 (Matheus)

E-mails institucionais: inserir antes da entrega

Abstract. *Phishing websites are created to imitate legitimate services and steal sensitive information. This work applies supervised machine learning to classify websites as phishing or legitimate. The PhiUSIIL Phishing URL dataset was used, containing 235,795 records and features extracted from URLs and web pages. After data analysis and preparation, Logistic Regression and Decision Tree models were trained and evaluated. The partial results were very high, reaching 99.99% accuracy with Logistic Regression and 100% with Decision Tree in the adopted train-test split.*

Resumo. *Sites de phishing tentam imitar páginas legítimas para roubar dados dos usuários. Este trabalho utiliza aprendizado de máquina supervisionado para classificar websites como phishing ou legítimos. Foi utilizado o conjunto PhiUSIIL Phishing URL, com 235.795 registros e características extraídas das URLs e das páginas. Após a análise e preparação dos dados, foram treinados modelos de Regressão Logística e Árvore de Decisão. Os resultados parciais foram altos, com 99,99% de acurácia na Regressão Logística e 100% na Árvore de Decisão no conjunto de teste utilizado.*

1. Introdução

Phishing é um tipo de golpe digital no qual o atacante tenta se passar por uma empresa, serviço ou pessoa confiável para obter dados como senhas, informações bancárias e credenciais. Uma forma comum desse ataque é o uso de páginas falsas visualmente parecidas com sites legítimos. Como novos endereços maliciosos podem surgir rapidamente, apenas listas de bloqueio nem sempre são suficientes [4, 3].

O aprendizado de máquina pode ajudar nesse problema ao identificar padrões em URLs, domínios e características das páginas. Neste projeto, a detecção foi tratada como uma classificação binária: phishing ou legítimo. O objetivo é comparar modelos simples de aprendizado supervisionado e verificar se eles conseguem identificar corretamente páginas suspeitas.

O projeto também se relaciona às ODS 9 e 16, pois busca contribuir para a segurança de infraestruturas digitais e para a redução de fraudes no ambiente online.

2. Fundamentação Teórica e Trabalhos Relacionados

No aprendizado supervisionado, o modelo recebe exemplos que já possuem uma classe conhecida e aprende padrões que podem ser usados para classificar novos casos. Neste projeto, a classe 0 representa phishing e a classe 1 representa um website legítimo.

Foram utilizados dois modelos nesta etapa. A Regressão Logística foi escolhida como um modelo de referência simples para classificação. A Árvore de Decisão foi escolhida por criar regras fáceis de interpretar a partir dos atributos disponíveis. Para avaliar os modelos foram utilizadas acurácia, precisão, recall, F1-score e matriz de confusão.

Trabalhos anteriores mostram que características de URLs e páginas podem ser utilizadas para detectar phishing com aprendizado de máquina [1, 4]. O conjunto PhiUSIIL, utilizado neste projeto, foi desenvolvido especificamente para estudos de detecção de phishing e inclui diferentes atributos relacionados à URL, ao domínio e ao conteúdo das páginas [2, 5].

3. Metodologia

A implementação foi feita em Python no Google Colab. Foram utilizadas principalmente as bibliotecas Pandas e NumPy para manipulação dos dados, Matplotlib para os gráficos e Scikit-learn para preparação, treinamento e avaliação dos modelos.

3.1. Coleta e entendimento dos dados

Foi utilizado o *PhiUSIIL Phishing URL (Website) Dataset*, disponível no UCI Machine Learning Repository [5]. O conjunto possui 235.795 registros, 54 atributos de entrada e uma variável alvo chamada `label`. No dataset, `label=0` representa phishing e `label=1` representa um website legítimo.

Entre os atributos disponíveis estão informações como tamanho da URL, tamanho do domínio, uso de HTTPS, presença de redes sociais, características do código da página e o índice `URLSimilarityIndex`.

3.2. Análise exploratória

Primeiro foi feita uma análise básica para entender o conjunto de dados. Foram verificados o número de linhas e colunas, os tipos das variáveis, valores ausentes, registros duplicados e a distribuição das classes. Não foram encontrados valores nulos nem linhas duplicadas.

Dos 235.795 registros, 100.945 são phishing (42,81%) e 134.850 são legítimos (57,19%). Como as duas classes possuem quantidades próximas, não foi necessário realizar balanceamento artificial nesta etapa.

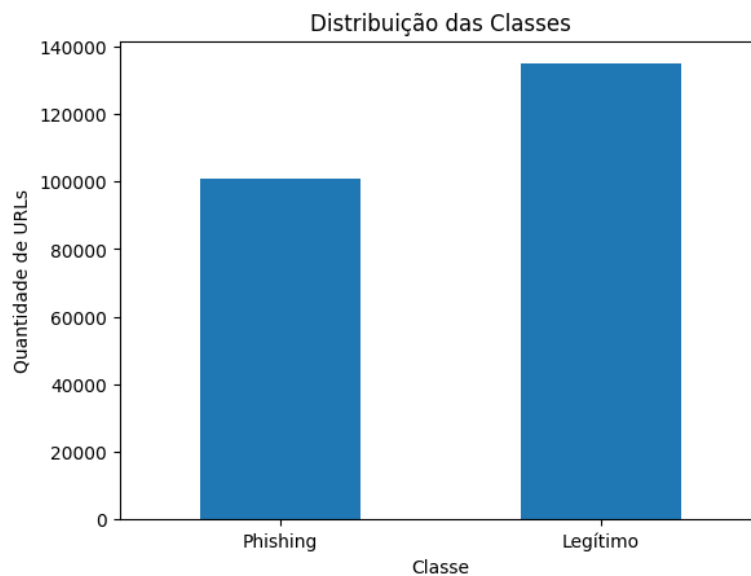


Figura 1. Distribuição das classes do conjunto de dados.

Também foi analisada a correlação entre os atributos numéricos e a classe. O atributo `URLSimilarityIndex` apresentou a maior correlação com a variável alvo, seguido por características como `HasSocialNet`, `HasCopyrightInfo`, `HasDescription` e `IsHTTPS`.

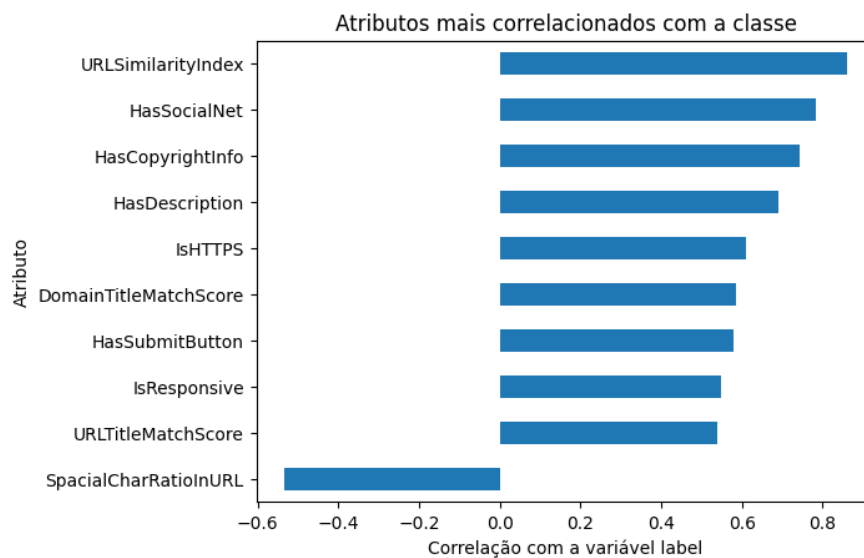


Figura 2. Dez atributos com maior correlação com a classe.

3.3. Preparação dos dados

Foram identificadas quatro colunas de texto: `URL`, `Domain`, `TLD` e `Title`. Como o dataset já possui vários atributos numéricos extraídos dessas informações, essas quatro colunas foram removidas do treinamento. Dessa forma, foram utilizadas 50 características numéricas como entrada dos modelos.

Em seguida, os dados foram separados em 80% para treinamento e 20% para teste. Isso resultou em 188.636 registros de treinamento e 47.159 registros de teste. A divisão foi estratificada para manter aproximadamente a mesma proporção de phishing e sites legítimos nos dois conjuntos. Foi utilizado `random_state=42` para tornar o experimento reproduzível.

Para a Regressão Logística, os atributos foram padronizados com `StandardScaler`. A padronização foi aplicada dentro de um *pipeline*, de modo que os parâmetros fossem calculados apenas com os dados de treinamento. A Árvore de Decisão não precisou de padronização.

3.4. Treinamento e avaliação

Foram treinados dois classificadores: Regressão Logística e Árvore de Decisão. Após o treinamento, os modelos fizeram previsões sobre os 47.159 registros do conjunto de teste.

Os resultados foram avaliados por acurácia, precisão, recall e F1-score. Para precisão, recall e F1-score, a classe phishing foi considerada a classe de interesse. Também foi utilizada a matriz de confusão para observar quantos casos foram classificados corretamente e quantos foram confundidos entre phishing e legítimo.

Além disso, foi analisada a importância dos atributos da Árvore de Decisão para entender quais características tiveram maior influência nas classificações.

4. Resultados Parciais

Os resultados obtidos até o momento são apresentados na Tabela 1.

Tabela 1. Resultados dos modelos no conjunto de teste.

Modelo	Acurácia	Precisão	Recall	F1
Regressão Logística	0,9999	1,0000	0,9997	0,9999
Árvore de Decisão	1,0000	1,0000	1,0000	1,0000

A Regressão Logística acertou 47.153 dos 47.159 registros de teste. Apenas seis páginas de phishing foram classificadas como legítimas, e nenhuma página legítima foi classificada como phishing.

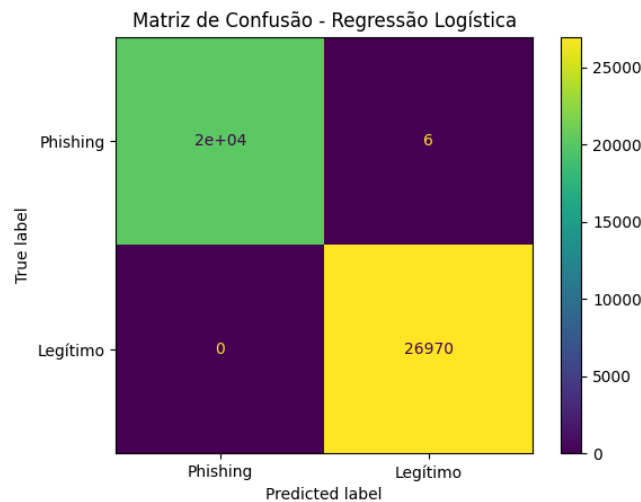


Figura 3. Matriz de confusão da Regressão Logística.

A Árvore de Decisão atingiu 100% de acurácia no conjunto de teste utilizado. A árvore apresentou profundidade 4 e 5 folhas. O atributo mais importante foi `URLSimilarityIndex`, seguido por `LineOfCode`. Esse resultado mostra que o conjunto possui características que separam muito bem as duas classes.

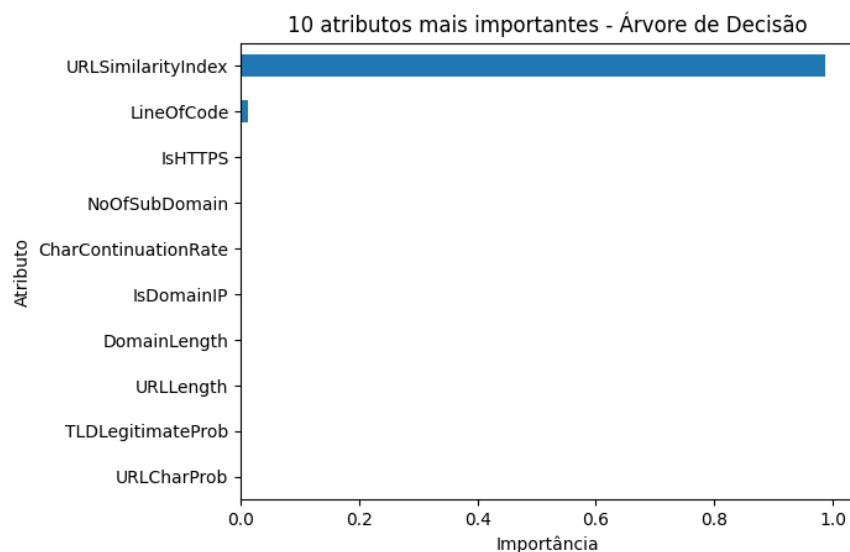


Figura 4. Importância dos atributos na Árvore de Decisão.

Apesar dos resultados muito altos, eles foram obtidos com uma divisão aleatória do próprio dataset. Portanto, na próxima etapa será importante testar o modelo em outros dados para verificar se o desempenho continua alto em situações diferentes.

5. Aspectos Éticos

O uso de um detector automático de phishing envolve alguns riscos. Um falso negativo ocorre quando uma página de phishing é classificada como legítima, podendo passar uma

falsa sensação de segurança ao usuário. Já um falso positivo ocorre quando um site legítimo é classificado como phishing e pode ser bloqueado ou sinalizado de forma incorreta.

Por isso, o modelo não deve ser considerado uma garantia absoluta de segurança. Em uma aplicação real, seria importante atualizar os dados com frequência, acompanhar os erros do sistema, testar novas versões do modelo e combinar a classificação automática com outras medidas de segurança.

6. Considerações Parciais

Nesta etapa foi possível carregar, analisar e preparar o dataset, além de treinar e avaliar os primeiros modelos. O conjunto apresentou classes relativamente equilibradas, não possuía valores ausentes nem duplicatas completas e forneceu 50 atributos numéricos para o treinamento.

A Regressão Logística obteve 99,99% de acurácia e a Árvore de Decisão atingiu 100% no conjunto de teste. Os resultados mostram que a proposta é viável, mas ainda será necessário testar a solução em outros cenários para avaliar melhor sua capacidade de generalização.

Repositório GitHub público: *inserir endereço do repositório antes da entrega.*

Referências

- [1] Karim, A., Shahroz, M., Mustofa, K., Belhaouari, S. B. and Joga, S. R. K. (2023). Phishing Detection System Through Hybrid Machine Learning Based on URL. *IEEE Access*, 11:36805–36822.
- [2] Prasad, A. and Chandra, S. (2024). PhiUSIIL: A diverse security profile empowered phishing URL detection framework based on similarity index and incremental learning. *Computers & Security*, 136:103545.
- [3] Safi, A. and Singh, S. (2023). A systematic literature review on phishing website detection techniques. *Journal of King Saud University - Computer and Information Sciences*, 35(2):590–611.
- [4] Sahoo, D., Liu, C. and Hoi, S. C. H. (2019). Malicious URL Detection using Machine Learning: A Survey. *ACM Computing Surveys*, 52(2):1–37.
- [5] Prasad, A. and Chandra, S. (2024). PhiUSIIL Phishing URL (Website) Dataset. UCI Machine Learning Repository, Dataset ID 967.

Dataset: <https://www.archive.ics.uci.edu/dataset/967/phiusiil%2Bphishing%2Burl%2Bdataset>